

Information Security (BDS-7A) – (CLO - 4) Quiz 04 (Fall 2024). Instructor: Dr. Syed M. Irteza		Name: SOLUTION
Date: 2024-11-11		Roll Number:
Total Marks: 10	Time Allowed: 10 mins	

1. If you have a well-defined hierarchy within your organization, e.g., CEO at the top, managers at the next level, and so on, then which access control model might be best suited for your organization? (2m)

Role-Based Access Control (RBAC). (Mentioning the complete name is enough for 2 marks)

Note: role hierarchies make use of the inheritance to enable one role to implicitly include access rights associated with a subordinate role.

2. What do we mean by a subject in the access control model? (2m)

Subject is an entity capable of accessing objects. (~ 1 mark)

A subject could be a user, a group of users, or a process. (~ 1 mark)

3. How does a capability ticket differ from an access control list? (2m)

Within discretionary access control, we may represent access control as matrices, with the subjects (or users) as the rows, and the objects (e.g., files) as the columns.

If we store the capability of individual users (i.e., subjects) to access the various objects (rows of the matrix), we call this a capability ticket. (~ 1 mark)

If we store a list of users (i.e., subjects) that have access to a specific object (i.e., columns of the matrix), we call this an access control list. (~ 1 mark)

4. In the cartoon example we discussed in example, which access control model seemed more appropriate given the specific nature of the use case? Can you think of another use case where that access control model might be the best model (in comparison to other models)? (4m)

ABAC – Attribute-Based Access Control (~ 1 mark)

➔ **Possible Use Case: A university intends to manage access to academic records, research data, and administrative documents.**

➔ **Attributes: Role (student, faculty, staff), department, course enrollment, data type (academic, administrative), and academic term.**

➔ **Policy Example: Faculty members can access students' academic records for courses they are teaching during the current term, but not for past or future terms. (see [this](#)).**

(~ 3 marks for any reasonable example, where more flexibility is needed than what RBAC can provide, or where it is obvious that attributes of subjects, objects or environment are more important than simply roles of the subjects. For example, seasonal offers can be modeled as environment attributes.)

Such a use case may become difficult if we used RBAC, since we would probably have to create more roles to manage the concept of a faculty member currently teaching a particular course.

In case a student has mentioned RBAC as the preferred access control model, along with a reasonable example, they can be given maximum partial credit of 2 marks.